

Cross-Account Access and Resource Sharing

Three ways across an account boundary, and when each is the wrong one.

Two of the three mechanisms grant **access to** a resource. RAM makes the resource **appear in** another account.

The three mechanisms

MECHANISM	WHAT CROSSES	TYPICAL USE
Role assumption	The caller, briefly	A human or workload acting in another account
Resource-based policy	Permission, attached to the thing	S3, KMS, SQS, SNS, Lambda, Secrets Manager
AWS RAM	The resource itself	Subnets, Transit Gateways, Resolver rules

ON THE EXAM

If the question is about infrastructure being duplicated in every account, it is a RAM question, not an IAM one.

Role assumption details the exam tests

- ◆ **Role chaining caps the session at one hour**, and it cannot be extended. This breaks long jobs.
- ◆ The trust policy names who may assume. The caller still needs **sts:AssumeRole** in their own policy.
- ◆ **External ID** for any third party, to defeat the confused deputy.
- ◆ Session tags let one role behave differently per caller, which is how ABAC reaches across accounts.

ON THE EXAM

A batch job dying at exactly sixty minutes is role chaining, every time. It is the most recognisable symptom in this domain.

What RAM can and cannot share

- ◆ **Networking:** subnets, Transit Gateways, Route 53 Resolver rules, prefix lists, Network Firewall rule groups.
- ◆ **Capacity:** Capacity Reservations, Dedicated Hosts, Aurora DB clusters, License Manager configurations.
- ◆ **Not S3 buckets.** Use a bucket policy. Not KMS keys either; use the key policy.
- ◆ Not security groups, and never the VPC itself. You share subnets out of a VPC, not the VPC.

ON THE EXAM

Anything with its own resource-based policy is shared with that policy, not with RAM. RAM covers what has no policy of its own.

RAM or a resource-based policy?

AWS RAM

The resource appears elsewhere

- For things with no policy of their own
- Share to an OU or a whole organisation
- Owner keeps control and pays
- Participants use it as if it were local

RESOURCE-BASED POLICY

Permission to reach across

- For S3, KMS, SQS, SNS, Lambda
- Scope with aws:PrincipalOrgID
- Both sides must allow the call
- The caller stays in their own account

THE TIEBREAKER

Ask whether the resource has a policy of its own. If it does, that is the tool. If it does not, RAM is the only option.

VPC sharing: the ownership model

- ◆ **You share subnets, never the VPC.** The VPC stays wholly owned by the owner account.
- ◆ **Owner keeps** route tables, network ACLs, gateways, endpoints and flow logs. Participants cannot change any of them.
- ◆ **Participants launch resources** into shared subnets, and own what they launch.
- ◆ Participants cannot use a security group owned by the owner or another participant. The default group belongs to the owner.
- ◆ Same organisation only, and default VPCs cannot be shared.

ON THE EXAM

Owner controls the network. Participants control their workloads. Nearly every shared-VPC question turns on which side of that line the problem falls.

Sixty accounts with their own VPCs means sixty NAT gateways, sixty endpoint sets and **sixty Transit Gateway attachments.**

The honest limits of a shared VPC

- ◆ **One IP pool.** A participant that fills a subnet blocks every other participant in it.
- ◆ Troubleshooting splits awkwardly. Security group problems are the participant's; route table and NACL problems are the owner's.
- ◆ Flow logs belong to the owner, so participants must ask for network evidence.
- ◆ Dedicated per-team subnets inside the shared VPC contain the address exhaustion risk.

ON THE EXAM

The blast radius moves rather than disappearing. You trade many small isolated failures for fewer, wider ones.

IAM Access Analyzer has three analyzers

- ◆ **External access.** Which resources are reachable from outside your zone of trust. Free.
- ◆ **Internal access.** Which principals **inside** your organisation can reach a chosen resource.
- ◆ **Unused access.** Unused roles, access keys, console passwords, and unused actions on a role.
- ◆ They are separate products. Enabling one in 2020 gave you nothing for the other two.

ON THE EXAM

Nobody outside was granted anything, yet the whole organisation can read it, means an internal access analyzer. External finds nothing there.

The rest of Access Analyzer

- ◆ **Policy generation** writes a least-privilege policy from what CloudTrail shows a principal actually did.
- ◆ **Custom policy checks** compare a proposed policy against your standards, so a pipeline can refuse a merge.
- ◆ **The zone of trust** is what counts as internal. An organisation-level analyzer treats the whole organisation as trusted.
- ◆ Set it up in a delegated administrator account, following module two's advice about the management account.

ON THE EXAM

Policy generation is the answer to we do not know what permissions this needs. It reads the evidence instead of guessing.

Reading the scenario

THE SCENARIO SAYS

The same infrastructure is rebuilt in every account

Too many NAT gateways, endpoints, TGW attachments

A job fails at exactly one hour

Who inside the org can reach this resource?

We do not know what permissions this app needs

A third party must access our account

IT IS POINTING AT

AWS RAM

Shared VPC subnets

Role chaining

Internal access analyzer

Access Analyzer policy generation

Cross-account role with an external ID

ON THE EXAM

Ask whether the problem is duplication or permission. Duplication is a sharing question; permission is an IAM one.

Meridian Freight gives each of its 60 delivery teams a dedicated AWS account with its own VPC. Every VPC has two NAT gateways, a set of interface endpoints, and a Transit Gateway attachment.

Finance has flagged that networking now costs more than the compute it serves. The network team also cannot keep routing consistent across 60 VPCs.

What should the solutions architect recommend?

- ☐ A Replace the Transit Gateway with VPC peering between the 60 VPCs
- ☐ B Share subnets from a central VPC with the team accounts using AWS RAM
- ☐ C Consolidate the 60 accounts into one account with 60 VPCs
- ☐ D Replace the NAT gateways with NAT instances to reduce cost

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A Peering instead of TGW

Sixty VPCs fully meshed needs 1,770 peering connections, none of them transitive. It makes the routing problem far worse.

C One account, 60 VPCs

Destroys account isolation, merges quotas and blast radius, and keeps all sixty sets of networking charges.

B Share subnets via RAM

One VPC means one set of NAT gateways, endpoints and one attachment. Accounts stay separate, so isolation and billing survive.

D NAT instances

Trades a managed service for 120 instances to patch, size and make highly available. It also leaves the endpoint and attachment costs untouched.

THE SIGNAL

Duplicated networking with separate accounts still required is the shared-VPC signature. The sprawl is the problem, not the account count.

After adopting a shared VPC, a participant team reports that they cannot add a route to a new on-premises range, and cannot see VPC Flow Logs while troubleshooting.

They have full administrator permissions in their own account.

What is the correct explanation?

- ☐ A Their administrator permissions need an explicit allow for ec2:CreateRoute
- ☐ B Route tables and flow logs belong to the VPC owner, and participants cannot modify or read them
- ☐ C An SCP on their OU is denying the actions
- ☐ D The resource share must be re-created with write permissions

◆ PAUSE AND DECIDE

What is the correct explanation?

- A

 Add an explicit allow
Administrator already allows the action. The block is not in their account's permissions at all.
- B

 Owner keeps the network
The sharing model gives participants the subnet and nothing else. Route tables, NACLs, gateways and flow logs stay with the owner.
- C

 An SCP is denying it
Plausible in general, and it would deny the action everywhere rather than only on someone else's resource. Nothing here suggests one exists.
- D

 Re-share with write
Invented. RAM shares do not have a write mode that would hand over the owner's route tables.

THE SIGNAL

Full admin in your own account and still blocked means the resource is not in your account. That is the shared VPC model working correctly.

A nightly data pipeline runs in a tooling account. It assumes a role there, then assumes a second role in each of 30 data accounts to copy files. The job takes about ninety minutes. It has begun failing partway through, always with expired credentials, and always at roughly the same elapsed time.

What is the cause, and what should be changed?

- ☐ A Role chaining caps the session at one hour; assume the target roles directly from the source identity
- ☐ B Raise the MaxSessionDuration on the target roles to twelve hours
- ☐ C The trust policies are missing a condition and should be widened
- ☐ D Request a quota increase for STS session length

◆ PAUSE AND DECIDE

What is the cause, and what should be changed?

- A

Role chaining, so assume directly

Chained sessions are capped at one hour regardless of settings. Removing the intermediate hop removes the cap.
- B

Raise MaxSessionDuration

The near miss. The setting exists and is ignored when a role assumes a role, so the session still ends at sixty minutes.
- C

Widen the trust policies

The credentials expired rather than being refused. Widening trust weakens security and changes nothing about duration.
- D

Quota increase

The one-hour chaining limit is a hard behaviour, not an adjustable quota. Support cannot raise it.

THE SIGNAL

Failure at a consistent elapsed time, with expired rather than denied credentials, points at a session limit rather than a policy.

A security team runs IAM Access Analyzer with an organisation-level external access analyzer, and reports zero findings on a sensitive S3 bucket holding customer records.

An internal review then finds that a broad identity policy lets every principal in the organisation read that bucket.

Why did Access Analyzer report nothing, and what should be enabled?

- ☐ A The analyzer was in the wrong Region; create one per Region
- ☐ B The organisation is the zone of trust, so internal grants are not external findings; enable an internal access analyzer
- ☐ C External access analyzers do not evaluate S3 buckets
- ☐ D The finding was archived automatically and should be unarchived

◆ PAUSE AND DECIDE

Why did Access Analyzer report nothing, and what should be enabled?

- A

 Wrong Region
External analyzers are per Region, so this is a genuine operational trap. It does not explain a bucket that was in scope and returned nothing.
- B

 Zone of trust; add internal analyzer
Everything inside the organisation is trusted by definition, so an organisation-wide grant is not external. Internal access analysis is the one that sees it.
- C

 S3 is not evaluated
S3 buckets are among the most commonly analysed resources. This is simply false.
- D

 Unarchive the finding
Archive rules suppress findings that were generated. No finding was ever produced here.

THE SIGNAL

An external analyzer is silent by design when the over-permission is internal. Enabling it once and assuming full coverage is the real error.

A central networking account has built Route 53 Resolver rules that forward queries for the company's private on-premises domains. Forty application accounts need the same resolution.

An engineer proposes copying the rules into each account and keeping them in step with a scheduled script.

What should the solutions architect recommend instead?

- ☐ A Share the Resolver rules with the organisation using AWS RAM
- ☐ B Keep the script but add a Config rule to detect drift
- ☐ C Create a private hosted zone in each account and associate it with each VPC
- ☐ D Grant each account a cross-account role into the networking account

◆ PAUSE AND DECIDE

What should the solutions architect recommend instead?

- A

 Share the rules with RAM
Resolver rules are RAM shareable. One rule set, shared to the organisation, and a new account inherits it with no copying.
- B

 Script plus drift detection
Keeps forty copies and adds monitoring of the copies. It detects the problem faster instead of removing it.
- C

 Private hosted zone per account
A hosted zone answers for a domain AWS hosts. These queries must be forwarded to on-premises resolvers, which is a different job.
- D

 Cross-account role
Lets someone administer the networking account. DNS resolution inside a VPC is not performed by assuming a role.

THE SIGNAL

One artefact needed identically in many accounts is the RAM signature. Copying and reconciling is the anti-pattern it removes.

A data engineering team wants every account in the organisation to read from a central S3 data lake bucket. Account numbers change as accounts are added and closed.

The team has opened a request to share the bucket using AWS RAM.

What should the solutions architect tell them?

- ☐ A RAM cannot share S3 buckets; use a bucket policy with an `aws:PrincipalOrgID` condition
- ☐ B Share the bucket with RAM, selecting the organisation as the principal
- ☐ C Create an access point per account and share those with RAM
- ☐ D List every account number in the bucket policy and update it monthly

◆ PAUSE AND DECIDE

What should the solutions architect tell them?

- A

Bucket policy with PrincipalOrgID
S3 has its own resource-based policy, so that is the tool. The condition key matches current membership, so the list maintains itself.
- B

Share via RAM
S3 buckets are not a RAM shareable resource type. The request cannot be fulfilled as asked.
- C

Access points via RAM
Access points are also not RAM shareable, and one per account reintroduces the maintenance the team is trying to avoid.
- D

List the accounts
Works today and is wrong by next month. A policy that must be edited whenever an account is created will eventually be forgotten.

THE SIGNAL

If a resource has its own policy, RAM is not involved. Pair this with scenario five: same shape of request, opposite answer.

What to carry out of this module

- ◆ **RAM shares the resource. Policies grant access to it.** Its own policy means RAM is not involved.
- ◆ **Share subnets, never the VPC.** Owner keeps routing, NACLs, gateways and flow logs.
- ◆ **Role chaining caps sessions at one hour.** MaxSessionDuration is ignored. Failure at sixty minutes is the tell.
- ◆ Access Analyzer is three analyzers. External finds nothing when the over-permission is internal.

ON THE EXAM

Ask first whether the problem is duplication or permission. That single question routes you to the right half of this domain.